

SIMATS ENGINEERING
ASSESSMENT TOOL 1

COURSE CODE: CSA5115

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 40%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

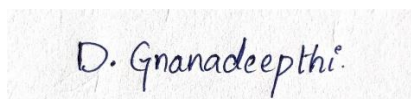
CONSTRAINT-BASED PROBLEM SOLVING

Code of Conduct:

I D. Gnana Deepthi (192411123) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:



Annexure A

CONSTRAINT-BASED PROBLEM SOLVING

1. A financial institution must secure all web transactions using TLS, but legacy systems only support older SSL versions. Design a solution to ensure secure communication.

Constraints:

- A. Backward compatibility must be maintained for 20% legacy clients
- B. Sensitive data must not be transmitted using SSL
- C. System downtime must be minimal during migration
- D. Cost of implementation should be optimized

2. An e-commerce platform is considering implementing the SET protocol for payment security but currently uses TLS-based encryption. Analyze and propose a decision.

Constraints:

- A. Must support high transaction throughput (10,000 transactions/minute)
- B. Compatibility with modern browsers is required
- C. Implementation complexity should be minimized
- D. Regulatory compliance (PCI-DSS) must be ensured

3. A corporate network is experiencing repeated malware infections that spread rapidly without user interaction. Propose a containment and prevention strategy.

Constraints:

- A. The network consists of 500+ interconnected systems
- B. Downtime per system should not exceed 10 minutes
- C. Detection must occur within 2 minutes of infection
- D. Solution must differentiate between virus, worm, and Trojan behavior

4. An organization needs to deploy a firewall architecture to protect its internal network from external threats and insider attacks. Design the solution.

Constraints:

- A. Must support both packet filtering and application-level inspection
- B. Latency introduced should not exceed 5 ms per request
- C. Should handle at least 1 Gbps traffic
- D. Must allow secure remote access for employees

5. A large enterprise network generates excessive false positives in its IDS, leading to alert fatigue. Propose an optimized IDS/IPS solution.

Constraints:

- A. Detection accuracy must be at least 95%
- B. False positive rate should be reduced below 5%
- C. System must process real-time traffic of 2 Gbps
- D. Solution should integrate with existing firewall infrastructure

ANSWERS

3. Containment and Prevention Strategy for Rapidly Spreading Malware

Introduction

A corporate network with more than 500 interconnected systems is vulnerable to rapidly spreading malware. Since the infections occur without user interaction, the attack may involve a worm, which can automatically exploit network vulnerabilities and spread from one system to another. A strong security strategy must provide detection within 2 minutes, limit system downtime to less than 10 minutes, and identify whether the malware behaves like a virus, worm, or Trojan.

A. Rapid Detection and Classification

The organization should deploy a centralized Endpoint Detection and Response (EDR) system on all systems. The EDR continuously monitors:

- Unusual process execution
- Unauthorized file modifications

- Rapid network connections to multiple devices
- Suspicious background services
- Abnormal privilege escalation

The system should classify malware based on its behavior:

- **Virus:** Attaches to files or programs and spreads when the infected file is executed.
- **Worm:** Automatically spreads across the network without requiring user interaction.
- **Trojan:** Appears to be legitimate software but secretly performs malicious activities.

A centralized Security Information and Event Management (SIEM) system can collect alerts from all 500+ systems and detect infections within the required 2-minute period.

B. Automated Containment

Once malware is detected, the infected system should be automatically isolated using Network Access Control (NAC) or EDR network isolation. The device can still communicate with the security server but is blocked from accessing other corporate systems.

This approach prevents a worm from spreading while reducing downtime. Automated actions include:

1. Isolate the infected endpoint.
2. Block its suspicious IP addresses and network connections.
3. Stop malicious processes.
4. Quarantine infected files.
5. Block the malware hash across all systems.

Automation helps contain the threat in seconds instead of waiting for manual administrator action.

C. Network Segmentation

The 500+ systems should be divided into separate network segments based on departments or functions. For example:

- HR Network
- Finance Network
- Development Network
- Server Network
- Guest Network

Firewalls and access control rules should restrict unnecessary communication between segments. Therefore, even if a worm infects one department, it cannot rapidly spread throughout the entire organization.

D. Prevention Measures

To prevent future infections, the organization should implement:

- Regular operating system and software patching
- Updated antivirus and EDR signatures
- Application whitelisting
- Multi-factor authentication for administrators
- Regular vulnerability scanning
- Restricted administrator privileges
- Secure backups for rapid recovery
- Email and web filtering to block malicious downloads

E. Downtime and Recovery Strategy

Because downtime must not exceed 10 minutes per system, automated remediation should be used. After isolation, the EDR should remove or quarantine malicious files and restart affected services if required. If the system cannot be cleaned automatically, a known-good backup or system image should be used for rapid restoration. Critical systems should also have redundant or backup systems to maintain business operations during recovery.

Conclusion

The best strategy is a combination of EDR, SIEM, automated isolation, network segmentation, patch management, and rapid recovery. The system can detect malware within 2 minutes, automatically isolate infected devices, and reduce downtime to less than 10 minutes. By analyzing propagation and execution behavior, the solution can effectively differentiate between a virus, worm, and Trojan, providing strong protection for a large corporate network.

4. Firewall Architecture for an Organization

Introduction

An organization requires a firewall architecture that protects its internal network from both external threats and insider attacks. The proposed design combines packet filtering,

application-level inspection, network segmentation, intrusion prevention, and secure remote access. The architecture is designed to handle at least 1 Gbps traffic while keeping latency below 5 ms per request.

A. Proposed Firewall Architecture

A three-zone firewall architecture can be implemented:

Internet → Perimeter Firewall → DMZ → Internal Firewall → Internal Network

- **Perimeter Firewall:** Filters incoming and outgoing Internet traffic using IP addresses, ports, protocols, and connection states.
- **DMZ (Demilitarized Zone):** Contains public-facing servers such as web, mail, and DNS servers.
- **Internal Firewall:** Separates the DMZ from internal systems and controls traffic between internal departments.
- **Internal Network:** Contains employee computers, databases, application servers, and other critical resources.

B. Packet Filtering

The firewall should use **stateful packet inspection** to examine:

- Source and destination IP addresses
- Source and destination ports
- TCP/UDP protocols
- Connection state
- Network interface

Only authorized traffic should be permitted. For example, HTTP/HTTPS traffic may be allowed to public web servers, while unnecessary ports should be blocked.

C. Application-Level Inspection

A **Next-Generation Firewall (NGFW)** should perform application-level inspection. It can identify applications even when they use common ports and inspect traffic for:

- Malware
- SQL injection attempts
- Suspicious HTTP requests
- Unauthorized applications
- Command-and-control traffic
- Data exfiltration attempts

This provides deeper protection than basic packet filtering.

D. Protection Against Insider Attacks

To protect against insider threats, the internal network should be divided into separate VLANs or security zones, such as:

- HR
- Finance
- Administration
- Development
- Server Network

Access between these zones should follow the **least-privilege principle**. Employees should only access the resources required for their jobs. Firewall logs should also be sent to a SIEM system for monitoring and detection of unusual activity.

E. Performance Requirements

The firewall should use hardware capable of supporting **at least 1 Gbps throughput**. High-performance packet processing, hardware acceleration, and load balancing can be used to maintain performance.

To ensure latency remains below **5 ms per request**:

- Use a high-performance firewall appliance.
- Avoid unnecessary deep inspection for trusted internal traffic.
- Use optimized firewall rules.
- Enable hardware acceleration.
- Monitor latency continuously.
- Use redundant firewalls in high-availability mode.

F. Secure Remote Access

Employees working remotely should connect through a **VPN**. The VPN should use strong encryption and **multi-factor authentication (MFA)**.

A secure remote-access process is:

Employee → VPN Gateway → Authentication + MFA → Firewall Policy Check → Authorized Internal Resource

Only authenticated and authorized employees should receive access to internal resources. Network-level access should be restricted according to the employee's role.

G. High Availability and Monitoring

Two firewalls can be configured in **active-passive high-availability mode**. If the primary firewall fails, the secondary firewall automatically takes over, reducing downtime.

Firewall logs should record:

- Blocked connections
- Allowed connections
- Failed login attempts
- VPN activity
- Suspicious applications
- Internal-to-internal traffic

Security administrators can analyze these logs to identify external attacks and insider threats.

Conclusion

The proposed architecture combines a **perimeter firewall, DMZ, internal firewall, stateful packet filtering, application-level inspection, network segmentation, and VPN-based remote access**. A high-performance NGFW with at least **1 Gbps capacity** can satisfy the traffic requirement, while optimized inspection and hardware acceleration can keep latency within the **5 ms limit**. This layered architecture provides effective protection against both external and insider attacks while maintaining secure remote employee access.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Problem Understanding	25%	Clearly defines the problem and identifies all relevant constraints accurately	Identifies most constraints with minor gaps	Partial understanding; misses key constraints	Fails to identify constraints correctly
Constraint Analysis	25%	Analyzes constraints effectively and prioritizes them logically	Provides reasonable analysis with some prioritization	Limited analysis; weak prioritization	No meaningful analysis or prioritization
Solution Development	25%	Develops optimal and feasible solutions satisfying all constraints	Develops workable solutions with minor limitations	Solutions partially satisfy constraints	Solutions do not meet constraints
Application of Concepts	15%	Effectively applies appropriate concepts, methods, or tools	Applies concepts with minor errors	Limited application; requires guidance	Unable to apply relevant concepts
Justification	10%	Provides strong justification for decisions with logical reasoning	Provides justification with some clarity	Weak or unclear justification	No justification provided

